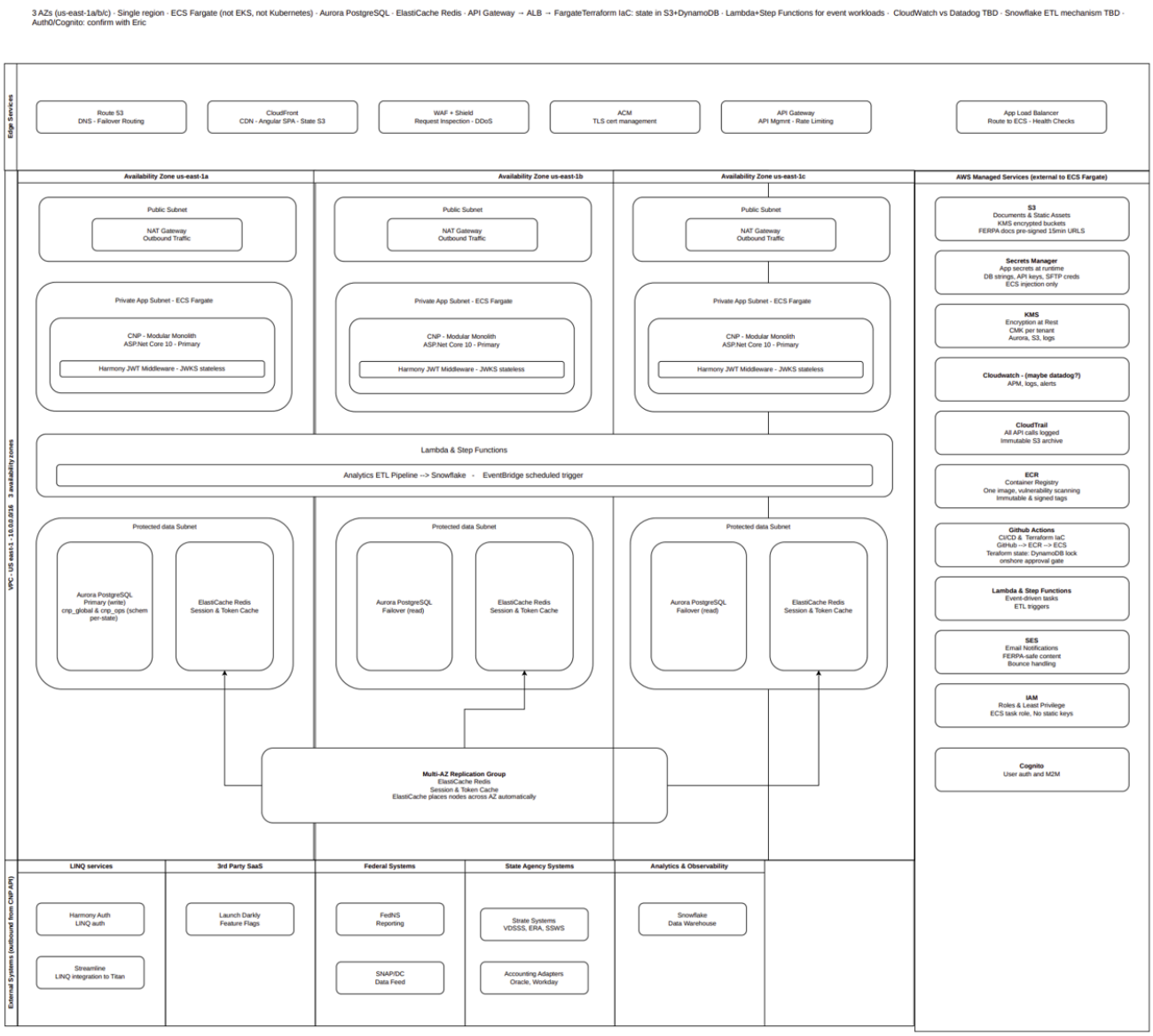
Infrastructure Requirements



1. Database Architecture

1.1 Two-Cluster Model

The platform uses two Aurora PostgreSQL clusters with completely different tenancy models.

	cnp_global	cnp_ops
What it is	One shared cluster, one schema	One cluster, one schema per state

What it contains	Federal codes, rates, program definitions, workflow state machines, RBAC catalog, form/review engine catalogs	All operational data: sponsors, sites, applications, claims, enrollments, audit logs
Approximate size	~387 tables	~1,015 tables per state schema
Who owns data	LINQ — no state can write here via the app	State agency data, isolated per state
Example schemas	cnp_global (single)	cnp_ops.ut, cnp_ops.wi, cnp_ops.me, cnp_ops.ak, cnp_ops.hi, cnp_ops.mo

Tenant boundary: The schema IS the tenant. There is no TenantId column in Aurora. A DBA connected to the wrong schema will see the wrong state's data with no warning. The application selects the schema from the authenticated JWT, never from user input

1.2 Why Not Separate Clusters Per State

Separate RDS clusters were evaluated and rejected: cost-prohibitive at 28 states, schema migrations require 28 independent pipeline runs, and connection pool overhead is unacceptable. The per-schema model gives state isolation at acceptable cost. Cross-region backup replication covers DR.

1.3 Two Database Roles

Two roles exist. No others should ever be created for application or human use.

Role	What it can do	Who uses it
cnp_ops (app role)	INSERT/UPDATE/DELETE on operational tables. READ-ONLY on schema-managed tables (WorkflowStates, ConfigDefinitions, etc.). Cannot run DDL.	Application service only — via Secrets Manager credential
cnp_migration	Full DDL on all tables. Used exclusively for migrations.	CI/CD pipeline only. Not available as an interactive credential. If anyone requests

		this credential directly, that is an access control violation.

cnp_migration is not for humans: This role must not appear in any Secrets Manager path accessible to engineers. It is provisioned only for the CI/CD pipeline. Issuing it as an interactive credential is a security violation.

1.4 IsFederal Guardrail Triggers

Two BEFORE INSERT OR UPDATE triggers enforce federal compliance at the database layer, not just the API layer. They fire for every write regardless of source — including direct SQL from a DBA, a data-fix migration, or any CI/CD script.

- trg_block_federal_transition_override on TenantTransitionOverrides
- trg_block_federal_config_override on TenantConfigOverrides

Both call log_federal_guardrail_violation() and raise a PostgreSQL exception on violation.

Never disable these triggers: Any migration that DROPs, DISABLEs, or modifies either IsFederal trigger must be blocked at review. These are the last line of defense when the API layer is bypassed.

DBAs must verify trigger integrity after every migration that touches the override tables.

1.5 State-Specific Schema Notes

Some states have additional schemas within the cnp_ops cluster that cannot be cleanly separated. These require decisions before Phase 3:

- Ohio: 42-table budget extension; also has fdp and gratefdp schemas
- Wyoming: fdp and gratefdp schemas (shared structure with Ohio — cannot be separated without schema surgery)
- Iowa: fnm schema
- Hawaii: Professional Standards tables (USDA-mandated, unique to Hawaii)

1.6 Audit Tables: Append-Only

Three tables in every cnp_ops state schema are append-only. Rows are never updated or deleted. Schema changes to these tables add columns only — no renames, no type changes, no

drops.

Table	Contents	Retention
AuditLogs	Every config write, cache-bust, workflow action, permission change	Permanent — never deleted
EntitySnapshots	Full JSONB snapshot of entity at each state change	Permanent — never deleted
FieldChangeLog	Individual field old/new values per change event — high volume	Permanent — never deleted

These tables will grow unboundedly. Partition by month from initial provisioning. Retrofitting partitioning on a large table is painful. Minimum index: (EntityType, EntityId, CreatedAt). GIN index on EntitySnapshots.DataJson if support/audit queries against snapshot content are expected.

1.7 Financial Column Type Requirement

Every financial column in the schema uses DECIMAL(18,2). No FLOAT, no REAL, no NUMERIC without explicit precision. Verify this at schema creation. If any migration or data-fix script casts a financial value to float, that is a bug that must be rejected.

1.8 Connection Pooling at Scale

The application uses a per-schema connection string (one per state). At 28 states in production, the cnp_ops cluster will see 28 distinct connection strings. PgBouncer or Aurora's native connection management must be configured for per-schema pools, not a single shared pool.

2. Secrets Management

2.1 Secret Store

AWS Secrets Manager. Region: us-east-1. The application uses an ISecretProvider interface that resolves to Secrets Manager in production, environment variables locally, and injected pipeline secrets in CI/CD. All paths follow a single naming convention.

2.2 Naming Convention

All secrets follow this pattern:

cnp / {environment} / {tenant-or-global} / {category} / {name}

Environments: dev | staging | prod

Tenant values: global | ut | wi | me | ak | hi | mo (etc.

Examples:

```
cnp/prod/global/db/cnp-global-rw          # cnp_global read/write
cnp/prod/ut/db/cnp-ops-rw                 # Utah cnp_ops read/write
cnp/prod/ut/dc-feed/snap-sftp             # Utah SNAP SFTP credentials
cnp/prod/ut/dc-feed/medicaid-api-token    # Utah Medicaid API token
cnp/prod/me/dc-feed/snap-sftp             # Maine SNAP SFTP credentials
cnp/prod/global/oidc/broker-signing-key   # OIDC signing key
cnp/prod/global/external/launchdarkly-sdk
cnp/prod/global/external/snowflake-svc
cnp/staging/ut/db/cnp-ops-rw              # Staging paths are separate
```

2.3 Rotation Schedule

Secret Type	Rotation	Who rotates	Notes
Database credentials (cnp_global, cnp_ops per-state)	90 days automated	Platform-managed	Application must tolerate overlap window — both old and new credentials valid briefly
DC feed SFTP credentials	Per state agency agreement	State agency initiates; LINQ onshore config team updates via API	Not platform-managed. Secure out-of-band channel only — not email
OIDC client secrets	180 days	Platform-managed	Or immediate on suspected compromise
External API keys (LaunchDarkly,	180 days	Platform-managed with graceful overlap	Old key valid during overlap window

Snowflake)			
Infrastructure credentials	TBD — needs infosec input	CloudOps + Infosec	Rotation frequency to be determined with infosec team

2.4 Access Scope Matrix

Principal	Paths accessible	Permissions
Application service (per tenant)	cnp/prod/{tenant}/* + cnp/prod/global/*	Read only
DC feed adapter	cnp/prod/{tenant}/dc-feed/*	Read only, scoped to its tenant
Onshore config admin	cnp/prod/{assigned-tenants}/dc-feed/*	Read, write, rotate — cannot access db or signing key paths
Platform operations	Global paths only	Read, write, rotate for platform-level secrets; no per-tenant access
Offshore engineers	cnp/dev/* and cnp/staging/* only	No production access — ever. Enforced structurally by IAM roles, not policy.

2.5 Hard Rules for Credential Handling

No credentials in config files: No SFTP hostname, username, password, PGP private key, or passphrase may appear in appsettings.json, environment variable files, Helm values, or source code. This is a PR-blocking finding.

- On SFTP auth failure: invalidate Secrets Manager cache and retry once with a freshly fetched secret. Never cache a failed credential for the process lifetime.
- PGP passphrases are stored as char[] (not string) so they can be zeroed after use.
- DC feed temp files (decrypted before parsing) must be cleaned up immediately after parsing completes.
- On suspected compromise: rotate immediately. Service outage is accepted over continued exposure.

- On confirmed incident: do NOT rotate credentials or delete logs until forensics is complete. Preserve all state.

2.6 Audit Trail for Secrets

Every create, read, update, rotation, revocation, and deletion event is logged. Two tiers:

- Read events: high-volume append-only log. Feed into anomaly detection — unusually high read rate on a specific secret may indicate credential stuffing.
- Rotation/revocation events: low-volume queryable store. Must be immediately queryable by the security team.

Anomalous access patterns (outside business hours, unexpected principals) trigger a security alert.

3. Infrastructure Requirements

3.1 Required Services

This is a discussion starting point. We will want recommendations here based on organizational standards.

Service	Purpose / Notes
Aurora PostgreSQL	cnp_global (one shared cluster) + cnp_ops (one cluster, per-state schemas). Private subnets only.
Amazon ElastiCache (Redis)	Config resolution cache (three-tier TTL per key). Cache-bust endpoint required. General config propagation: under 5 minutes.
ECS Fargate	API service + Angular frontend task definitions.
Application Load Balancer	HTTPS termination. Valid certificate required for demo and prod domains.
AWS Secrets Manager	All credentials. Paths must be documented and provisioned before any service deploys.
S3	Form PDF snapshots (Document Library). Presigned URL generation for historical form access. Encryption at rest required. Versioning enabled. No public access.
Snowflake	CDC pipeline target for cross-state analytics. Service account: cnp/prod/global/external/snowflake-svc. TenantCode injected by CDC

	pipeline — does not exist in Aurora.
VPC	Private subnets for Aurora, Redis, and ECS tasks.
GitHub Actions	CI/CD: build → test → deploy to staging on PR merge; deploy to demo on tag. cnp_migration role is used here only.
Cognito	OIDC provider (decision required Sprint 1 — see Section 3.4). Signing key at cnp/prod/global/oidc/broker-signing-key.
LaunchDarkly	~47 feature flags. SDK key: cnp/prod/global/external/launchdarkly-sdk. Must have environments matching: dev, staging, UAT, demo, prod.

3.2 Environments — All Ephemeral Except Production

All non-production environments are on-demand: spun up by the CI/CD pipeline or an operator trigger and torn down when no longer needed. Production is the only persistent environment. No environment is kept running idle.

Every non-production environment must be fully provisionable from a single IaC command or pipeline trigger. That means Aurora cluster (or schema), Secrets Manager path seeding, ECS task definitions, ALB, and LaunchDarkly environment are all scripted. If any of those cannot be automated, the on-demand model does not work. This should be push-button with permissions for the Engineering team.

Environment	Lifecycle	Purpose	Notes
Dev	On-demand per engineer	Individual feature development	Spun up by developer via IaC script. Synthetic data only. Shared Secrets Manager dev paths. Offshore engineers have access.
Test	On-demand per PR/branch	Automated integration testing	Created by CI/CD on PR open; torn down on PR close or merge. Synthetic data only. Nightly data reset if long-lived.
Staging	On-demand per release candidate	Pre-release validation	Promoted from Test. Torn down after sign-off. Full state migration run. Synthetic data only.
UAT	On-demand per UAT cycle	User acceptance testing — state	Provisioned on request; includes real-ish seed data (sanitized). Torn down after UAT

		agency or internal	sign-off. Separate Aurora cluster per spin-up.
Demo	On-demand per demo event	Sales / stakeholder demonstrations	Stable seed data. Spun up before demo; torn down after. No uncontrolled deploys during a live demo window.
Production	Persistent	Live state data	Onshore only. Break-glass required for any direct access. Never torn down.

3.3 On-Demand Provisioning Requirements

For on-demand environments to work, CloudOps must script every resource that an environment depends on. Manually provisioned resources are blockers because they break the automation model.

An environment without its Secrets Manager paths cannot start. The seed script must run before the ECS tasks are registered. If any path is missing, the service will fail to boot and the failure message will expose which secret name was missing. Write the seed script before standing up any environment.

Resource	Provisioning Requirement	Teardown Requirement
Aurora cluster / schema	IaC script creates cluster (UAT, Demo) or schema-only (Dev, Test, Staging). Migration pipeline runs automatically on provision.	Drop schema or cluster. S3 data retained per retention policy.
Secrets Manager paths	Seed script creates all cnp/{env}/{tenant}/* paths with synthetic credentials on provision. No manual secret creation.	All paths under cnp/{env}/* deleted on teardown.
ECS task definitions	Task definitions registered per environment with correct Secrets Manager ARNs injected at provisioning time.	Task definitions deregistered; ECS service deleted.
ALB / DNS	ALB listener rule and DNS record created per	Listener rule and DNS record removed on teardown.

	environment (e.g., staging-{run-id}.cnp.linq.com).	
LaunchDarkly environment	Environment created in LaunchDarkly project via API. SDK key seeded into Secrets Manager.	Environment archived in LaunchDarkly on teardown.
Redis (ElastiCache)	Dev/Test/Staging: shared ElastiCache instance with namespace isolation. UAT/Demo: dedicated instance.	Shared: namespace flushed. Dedicated: cluster deleted.
S3 buckets/prefixes	Dev/Test: shared bucket with per-environment prefix. UAT/Demo: dedicated bucket.	Shared: prefix purged. Dedicated: bucket deleted.

3.4 OIDC Provider

Decision required Sprint 1. This affects ECS provisioning and Secrets Manager paths.

Preferred choice is LINQ Harmony Auth (auth.linqharmony.com) as reuse over rebuild. Two requirements below must be confirmed before Sprint 1 commit. If either cannot be met, fall back to Cognito (managed AWS).

1. Harmony Auth supports per-state tenant isolation at the client/connection level becauseCNP has one schema per state and the auth layer must mirror that boundary
2. Client provisioning and teardown can be scripted via API to support on-demand environments (the /connections/{connectionId}/disableClient endpoint is a promising signal). If both are confirmed, Harmony Auth is the choice. API reference: Harmony Auth API

3.5 Multi-Region

Not multi-region until the DR plan is finalized. Cross-region backup replication is configured (primary: us-east-1, secondary: us-west-2) but active multi-region failover is not live.

4. Deployment & Migration

4.1 Migration Tooling

FluentMigrator or EF Core Migrations (decision pending — either is supported by the design). Migrations run per-schema:

- cnp_global: runs once per deployment — one schema, all environments
- cnp_ops.{state}: runs per state — each state migrates independently

The cnp_migration DB role is used exclusively during migrations. It is provisioned only in the CI/CD pipeline. See Section 1.3.

4.2 Per-State Deployment Independence

Because schemas are per-state, migrations are independent. This is a feature, not a constraint:

- A migration that fails for one state does not affect other states
- States can be held at a prior schema version during their SFSP operational blackout (May–August) without blocking other states from receiving updates
- New states onboard via the Tenant Onboarding API — POST /tenants/{tenant}/scaffold?similarTo=UT — and then their schema runs the full migration sequence

4.3 What Requires a Code Deployment

These actions require a full CI/CD deployment pipeline:

- New named condition hook in the workflow engine
- New WorkflowState (requires data migration in cnp_global and possible UI changes)
- New IsFederal row (migration review by senior onshore engineer required)
- New external system integration (accounting adapter, DC feed adapter)
- New config key (must be seeded via DB migration before operators can set overrides)

4.4 What Does NOT Require a Deployment

These can be done via API with no code change or pipeline run:

- Onboard a new state
- Update annual reimbursement rates (INSERT with EffectiveDate into cnp_global)
- Future-date a config change (override written in April, effective July 1, no deployment)
- Register a DC feed credential update (via DC Feed Adapter API only)
- Register an accounting adapter (after adapter code is deployed, registration is config-only)

4.5 Schema Gap to Verify

TenantErrorConfig was added to cnp_ops schema in July 2026. Verify this table is present in all existing state schemas before any state goes live on the new platform.

5. Production Access Controls

5.1 Production Access Matrix

Role	Prod DB	Dev/Staging DB	Secrets Manager	Schema Migrations
Onshore engineer	Read-only via break-glass	Full	Full	Via CI/CD only
Onshore config admin	Config writes via API only (no direct DB)	Full	dc-feed paths only	Via CI/CD only
Offshore engineer	NONE — ever	Synthetic data only	NONE — ever	Via CI/CD only
LINQ DBA	Read-only by default; break-glass write	Full	Full	Via CI/CD only
State agency admin	Own state via app only	No	None	N/A
FNS Auditor	Read-only for assigned states via app	No	None	N/A

5.2 Break-Glass Procedure

Break-glass system does not exist yet: This is a hard gate. Until it is built, there is no sanctioned path for any engineer to access production data directly. Build this before any production environment is provisioned.ed.

When built, the procedure will be:

- Engineer submits a request through the access management system with a business justification

- Access is granted for a time-limited session
- Session is logged with the justification provided
- Anomalous activity during a break-glass session is classified as a security incident
- This process applies to onshore engineers and DBAs. It is never available to offshore contractors.

5.3 Offshore Contractor Hard Rules

These are structural controls, not policy statements:

- Zero access to production environments, production databases, production AWS accounts, or production Secrets Manager paths
- Zero access to production credentials — enforced by IAM roles that physically cannot reach production Secrets Manager paths, not just policy
- Staging environments accessible to offshore engineers contain synthetic data only. Column masking is explicitly called out as insufficient — re-identification risk is high for small-population states like AK, HI, and ME.
- All PRs touching compliance logic (IsFederal configuration, audit trail, federal math, named workflow hooks) require review and approval from a US-based onshore engineer before merge
- Offshore engineers cannot export data from any LINQ environment. DLP controls must be active on all environments they can access.
- Offshore engineers must have individual named accounts. Shared credentials are prohibited.
- Access is revoked within 24 hours of a contractor's engagement ending. The engagement manager must notify access management — a contractor's departure alone does not trigger automatic revocation.

5.4 Gate Before Offshore Team Receives Any Access

Per the October Prototype build plan, the following must be in place before the offshore team receives access to any LINQ environment:

- AWS environments (dev/staging) provisioned
- Secrets Manager paths documented for all dev/staging environments
- Individual named accounts provisioned for each offshore engineer
- Design document package delivered to offshore team
- DLP controls deployed and verified

6. Compliance Requirements

6.1 NIST SP 800-171

Child nutrition eligibility data qualifies as Controlled Unclassified Information (CUI). NIST SP 800-171 applies — 110 requirements across 14 control families. A formal gap assessment is required before production go-live (currently NOT STARTED).

Control families with direct CloudOps/DBA action items:

Family	Code	CloudOps/DBA Implication
Access Control	AC	RBAC, schema isolation, break-glass, offshore structural restrictions
Audit & Accountability	AU	AuditLogs, EntitySnapshots, FieldChangeLog — append-only, Secrets Manager audit trail
Configuration Management	CM	IsFederal triggers, migration review gates, config hierarchy enforcement
Identification & Auth	IA	OIDC via Harmony Auth /Cognito, individual accounts only, no shared credentials
Contingency Planning	CP	DR plan must be finalized and tested — currently under assessment
Incident Response	IR	Break-glass logging, forensic preservation rule, breach notification SLAs
Media Protection	MP	No real data in dev/staging, DLP controls, S3 encryption at rest
System & Comms Protection	SC	VPC private subnets, HTTPS everywhere, no credentials in config files

6.2 FERPA

LINQ is a school official under FERPA when processing eligibility data on behalf of state educational agencies. Obligations include: no disclosure to third parties without consent, access controls, and breach notification. State-specific Data Processing Agreements (DPAs) must confirm FERPA coverage before any real student data is processed on the new platform. Legal must confirm DPA coverage for all states going live.

6.3 Breach Notification Timelines

Notification Target	Deadline
LINQ Security lead + VP Engineering	Within 1 hour of detection
Legal	Within 4 hours of detection
State agency	Within 24 hours of confirmed breach
USDA FNS	Consult Legal — may be required if program integrity is affected
State law deadline (varies)	Legal must determine per state. AK, HI, ME, MO, UT, WI have minimum 72-hour windows. Most restrictive state law applies across all 28 states.

7. Backup & Disaster Recovery

Targets are proposed, not confirmed: The DR plan has been flagged as not finalized in the Access Governance document. Do not treat the targets below as commitments until the DevOps/Engineering lead signs off. A confirmed DR plan and successful restore test are required before first state go-live.

7.1 Proposed Backup Targets

- Aurora automated backups with point-in-time recovery (PITR): 35-day retention
- Daily snapshots: retained 1 year
- Cross-region backup replication: primary us-east-1, secondary us-west-2

7.2 Proposed Recovery Targets

- RPO: 1 hour

- RTO: 4 hours

7.3 DR Test Requirement

A full DR restore test must be completed before first state go-live and annually thereafter. This is a hard gate. A production system handling federal child nutrition data with no confirmed DR plan is not compliant with NIST SP 800-171 CP and IR control families.

7.4 Schema Isolation and DR Implication

Because cnp_ops uses one cluster with per-state schemas (not separate clusters), a single Aurora cluster failure affects all states simultaneously. The DR runbook must cover:

- How to restore a single state schema from cluster-level PITR without affecting other states
- Which state to prioritize if multiple states are affected simultaneously
- SFSP seasonal consideration: May–August operational blackout in SFSP states — DR procedures must prioritize SFSP data recovery during this window for affected states

8. Performance & Indexing

8.1 Audit Tables — Partition from Day One

AuditLogs, EntitySnapshots, and FieldChangeLog are append-only and grow unboundedly. Retrofitting partitioning on these tables after they contain production data is expensive. Provision them with monthly or yearly partitioning from initial schema creation.

- Minimum index: (EntityType, EntityId, CreatedAt)
- GIN index on EntitySnapshots.DataJson if support or audit queries against snapshot content are anticipated
- FieldChangeLog is high-volume — consider a more aggressive archiving policy than EntitySnapshots

8.2 Config Resolution Index

The ICnpConfigService resolves config via a COALESCE across ConfigDefinitions (cnp_global) and TenantConfigOverrides (cnp_ops) with effective-date filtering. This runs on every API request that reads config, but the result is cached in Redis. The underlying query must be indexed on TenantCode, ProgramCode, and EffectiveDate to ensure cache misses resolve quickly.

8.3 DC Feed Idempotency Index

DC feed staging tables use a SourceRowHash CHAR(64) NOT NULL column (SHA-256 of raw row bytes) for idempotency. This column must have a unique index per state schema to prevent duplicate row ingestion on retries.

8.4 FormFieldValues — Future Sizing Consideration

The Form Engine stores every form field value as a row in FormFieldValues (one row per field per form instance). Across all active states and claim seasons, this table will become one of the largest in the system. While it is out of scope for initial provisioning, the indexing strategy on (InstanceId, FieldCode) and (FieldCode, FieldValue) should be designed before the first state reaches high claim volume.

8.5 EAV Query Pattern Advisory

FormFieldValues and ReviewAnswers use an Entity-Attribute-Value pattern. All values are stored as TEXT — the database has no knowledge of types. Queries that filter or aggregate on specific field values require multi-table joins against the field catalog. State FNS report queries and any analytics that reference specific form field responses will be substantially more complex than equivalent queries against typed columns. Ensure the reporting layer designers are aware of this pattern before report query work begins.

9. S3 & File Storage

9.1 Form PDF Snapshots

The Document Library generates PDF form snapshots stored in S3. FormSnapshot (PDF in S3) is the legal record. EntitySnapshots in Aurora is the machine-queryable companion. Presigned URLs are generated at read time — forms are never served directly from Aurora.

9.2 S3 Bucket Requirements

- Per-state isolation at the object key level at minimum — consistent with the schema-per-tenant model in Aurora
- Document versioning must be enabled
- Encryption at rest required (NIST SP 800-171 MP controls)
- No public access on any CNP bucket
- Bucket policy must restrict access to the platform ECS task role only — no cross-state prefix access

- Presigned URL TTL must be bounded — long-lived presigned URLs on federal child records create a compliance exposure

FERPA note: Form snapshots contain child nutrition eligibility data. S3 access policy must be as restrictive as the Aurora schema access policy.

10. Direct Certification Feed — SFTP & PGP Infrastructure

10.1 Overview

Each participating state sends student eligibility data via a per-state adapter. Transport and encryption vary by state. The adapter is registered in cnp_global; credentials live in Secrets Manager only.

10.2 Per-State Examples

State	Transport	Capabilities	Secrets Manager Paths
Indiana	SFTP + PGP (download only)	SftpDownload, PgpDecrypt	cnp/dc/IN/sftp (connection), cnp/dc/IN/pgp (key + passphrase)
Hawaii	SFTP + ZIP (bidirectional)	SftpDownload, SftpUpload, ZipUnwrap, ZipWrap, Bidirectional	cnp/dc/HI/sftp (connection)

10.3 SFTP Session Rules

- Sessions must not be held open across long-running operations — open a session, complete its operation, disconnect immediately
- Hawaii bidirectional: two separate sessions (one for download, one for upload) — do not hold the download session open while staging and matching occurs
- On auth failure: invalidate Secrets Manager cache and retry once with a freshly fetched credential. Do not re-cache on failure.

10.4 PGP Key Requirements

- PGP private keys in AWS Secrets Manager only — never in config files, source code, or environment variables

- Passphrases stored as char[] (zeroed after use) — not String objects
- Decryption writes to a temp directory only; temp files are cleaned up immediately after parsing

10.5 Credential Rotation for External SFTP

DC feed credentials are issued by state benefit agencies — LINQ does not control rotation timing. When a state agency initiates rotation:

- State agency notifies LINQ at minimum 24 hours in advance
- Onshore config team receives new credential through a secure out-of-band channel (not email)
- Onshore engineer updates Secrets Manager via the DC Feed Adapter API — no deployment, no code change
- Next scheduled feed run picks up the new credential automatically

11. Monitoring & Audit Requirements

11.1 What Must Be Monitored

- Secrets Manager: high read-rate anomalies on specific secrets (possible credential stuffing)
- Secrets Manager: access outside business hours or by unexpected principals — immediate security alert
- Break-glass sessions: all activity during a session must be captured; anomalous activity is classified as an incident
- Cache-bust calls: every POST /admin/config/cache/bust logged to AuditLogs with actor identity
- IsFederal trigger violations: log_federal_guardrail_violation() logs to a queryable store; any violation is an incident

11.2 Snowflake CDC Pipeline

Aurora-to-Snowflake CDC pipeline adds TenantCode to all replicated rows before writing to Snowflake. This is the only location TenantCode exists as a column — it is not present in Aurora. The Snowflake service account credential is at cnp/prod/global/external/snowflake-svc. Low-count suppression applies in analytics: query results returning fewer than 5 individuals are suppressed to prevent re-identification of small-population states.

11.3 Incident Response Logging Rule

Do not rotate or delete on incident detection: When a security incident is detected, do NOT perform routine credential rotation or log cleanup. Preserve all state until forensics is authorized. Rotating credentials or purging logs before forensics is complete can destroy evidence needed for breach notification compliance.